

Behavior Analysis

4/18/26 1:37 PM

Anomalies with Behavioral Analysis

Frequency → timing/volume
Protocol → rule deviations
Population → group outliers

1. Network Behavioral Analysis (NBAD) Fundamentals

What is NBAD? Behavioral analysis of network traffic to detect anomalies that signatures miss. Focuses on timing, volume, and patterns instead of static strings.

Why it matters: Signatures are fast but limited. Behavioral methods catch:

- Scans
- Beaconsing/C2
- Brute force
- Tunneling
- Encrypted exfiltration

Key Data Sources:

- SPAN/mirror ports from switches (web servers, clients, domain).
- Tools: **Moloch** (PCAP storage + visualization), **Zeek/Bro** (protocol logs), **SiLK** (flow analysis), **Elasticsearch + Kibana** (dashboards).

Practice How You Play: Always baseline normal traffic before hunting anomalies.

2. Frequency Analysis

Core Idea: Compare how often or when events happen relative to normal behavior.

Useful Frequency Techniques:

- **Count per time unit:** Logins per minute, connections per second.
- **Percentage of total:** % of UDP vs TCP, % of traffic to one port.
- **Time between events:** Regular intervals (beaconing) vs human randomness.

What a Scan Looks Like:

- One-to-many: Single IP sending packets to many IPs/ports.
- Indicators: Short sessions (<1 second), many SYN without ACK, high volume from one source.
- Internal scan: Same pattern inside your network (higher risk).

Detection Example (Bro script for attempted connections):

- Threshold: 5+ attempted connections per minute from one origin.
- Use rstats or Bro to count per source IP.

What Beaconing Looks Like:

- Regular, periodic connections to the same external IP/port.
- Indicators: Consistent timing, same packet sizes, low data volume.

Identifying Beaconing:

- Compare to normal web traffic: Normal has irregular timing; beaconing is perfectly spaced.
- Use Timelion/Kibana to visualize session duration over time.
- Filter short sessions or consistent intervals.

What Command & Control Looks Like:

- Malware checks in, receives commands, sends results.
- Often over HTTP/HTTPS or DNS to blend in.
- Indicators: Small, regular POSTs or queries; encoded data in subdomains.

Identifying C2:

- DNS C2: High-entropy subdomains, TXT/MX records, long queries.
- HTTP C2: Consistent short sessions, unusual JA3 hashes.
- Use entropy scoring (Bro script) or JA3 to spot outliers.

What Brute Force Looks Like:

- Rapid, repeated login attempts (username/password guessing).
- Indicators: Many short sessions to same port (RDP=3389, SSH=22), consistent packet counts, failed auth patterns.

Identifying Brute Force:

- RDP: 6–7 packets per failed attempt, short duration (~30ms).
- Success: Longer sessions with more packets.
- Use packet count + duration filters in Bro/SiLK.

Fitting Frequency Analysis into Daily Operations:

- Automate with cron jobs or tool APIs.
- Use for real-time alerts or historical hunts.
- Combine with other methods (protocol + population) for stronger signals.

3. Protocol Analysis

Core Idea: Understand normal protocol behavior per RFC, then spot deviations.

Following the Rules:

- Protocols must mostly follow standards to interoperate.
- Deviations (wrong flags, unusual record types, unexpected ports) = red flag.

Discovering DNS Command & Control:

- Normal DNS: Short queries, A/AAAA records, low volume.
- Malicious DNS: High-entropy subdomains, TXT records with large data, DNS over TCP for small queries.
- Detection: Entropy scoring (Bro script), unusual record types, direct queries to internal DNS from clients.

Deducing Activity of Encrypted Web Traffic (HTTPS):

- Normal: Varied timing, standard JA3 hashes, proper certificates.
- Malicious: Consistent short sessions, rare JA3 hashes, self-signed certs, unusual ports (e.g., 8888).
- Detection: JA3/JA3s hashes, certificate issuer checks, session duration analysis.

Analyzing SSH Authentication Behavior:

- Normal: Varied session lengths, standard key exchange.
- Brute force: Consistent packet count (~78 packets per failed attempt), short duration.
- Detection: Packet count per session + Bro SSH logs (auth success/failure).

Customizing DHCP Detection:

- Normal DORA: Discover → Offer → Request → ACK.
- Malicious: Rogue DHCP (bad options, exhaustion), unusual router/DNS settings.
- Detection: Hostname regex, router option validation, MAC randomization patterns.

Exploring Other Protocols:

- Focus on high-volume ones in your environment (LDAP, FTP, NTP, etc.).
- Apply same methods: baseline normal behavior, look for deviations in timing/volume/fields.

Key takeaway: Protocol analysis = know the rules, then find what breaks them.

4. Population Analysis

Core Idea: Compare behavior of one entity (IP, client) against the group (all clients).

Leveraging Machine Learning:

- Discover encrypted exfiltration by spotting outliers in HTTPS traffic volume or patterns.
- Tools: Elasticsearch machine learning jobs on client populations.

Investigating Client Device Relationship Anomalies:

- Look for unusual client-to-client communication (e.g., finance VLAN talking to engineering VLAN).
- Indicators: SMB transfers between unexpected subnets, RDP from scanning host.

Revealing Hidden Connections:

- Use connection graphs (Moloch) to visualize relationships.
- Combine with JA3, session duration, and frequency to link events.

Successfully Integrating Network Triage:

- Frequency → timing/volume anomalies.
- Protocol → rule deviations.
- Population → group outliers.
- Combine for stronger signals and fewer false positives.

Tuning Alerts:

- Whitelist known good JA3, hostname patterns, session behaviors.
- Aggregate alerts (e.g., one alert per 100 occurrences).
- Use dashboards (Kibana, Moloch) for visualization.

Recording Results:

- Use case management (TheHive) to link observables across alerts.
- Merge related cases when shared IPs, JA3, or files appear.

Putting It All in Perspective:

- NBAD fills gaps in signature-based detection.
- Still need host logs, application data, and machine data for full picture.
- Missing links: Process details, actual data moved, user actions.

Key takeaway: Behavioral analysis turns noise into signals. Combine frequency, protocol, and population methods with other data pillars for complete triage.